

AI Critique — HW06 (§10)

AI được dùng để sinh test case, audit, dựng harness Postman/Newman và CI. Nhận xét tập trung vào hai chỗ AI sai rõ nhất, lập chứng trong `test-cases/*/audit.md` và `ai-audit-report.md`.

AI sai ở đâu. Thứ nhất, AI giả định SUT tuân đặc tả: model mặc định email trùng bị từ chối 409, mật khẩu yếu bị chặn, PUT/DELETE một `id` không tồn tại trả 404, và CRUD danh mục đòi quyền admin. SUT thật không có ràng buộc nào trong số đó — chèn bản ghi trùng và trả 200, chấp nhận mật khẩu `123`, trả 200 cho `id` không tồn tại, cho user thường tạo/sửa/xóa danh mục. Tin AI thì các case này bị đánh "pass" và ba lỗi thật (BUG-FR14-001 broken access control, FR01-001 no-uniqueness, FR08-001 IDOR) bị bỏ sót. Thứ hai — nghiêm trọng hơn — AI **bịa cả bản prompt-log**: viết lại prompt từ trí nhớ thay vì trích verbatim, tạo bằng chứng audit giả trông hợp lý.

Vì sao AI không tự phát hiện. Cùng một gốc: AI không có oracle runtime. Nó suy luận từ "một REST API đúng chuẩn phải thế nào" thay vì hành vi quan sát được của SUT cụ thể. Với prompt-log, model tối ưu cho tài liệu "trông đủ" thay vì bản ghi kiểm chứng được — tự tin y như khi nó đúng.

Nguyên tắc rút ra. Mọi output AI đều là giả thuyết phải đối chiếu với thật: test case đối chiếu response thật của SUT, bằng chứng quy trình đối chiếu transcript gốc. Audit của con người không phải nghi thức — đó là chỗ duy nhất sự lạc quan-theo-đặc-tả của AI bị bắt trước khi thành điểm số.